

SAP Field Report: Operational Validation

docs/field_report_openrouter_v1.md

Classification: Public Evidence of Use — Confidential Details Redacted
Protocol: Symbiotic Architecture Protocol (SAP)
DOI: [10.5281/zenodo.21925439](https://doi.org/10.5281/zenodo.21925439)
Repository: [SAS-Prompt-Symbiotic-Agent](#)

1. Environment Registration

Field	Value
Origin Node	thaliondris1999
Agent Model	DeepSeek V4 Flash (via API)
Interface	GitHub Copilot Chat / OpenRouter
Target Class	Two public bug bounty programs (marketplace platform + financial infrastructure)
Architecture Audited	Web applications with GraphQL/REST APIs, JWT-based authentication, payment processing flows, third-party integrations
Session ID	SAP-FIELD-001
Execution Window	2026-08-09 to 2026-08-13
Jurisdiction	International bug bounty scope —coordinated disclosure regime

Sensitive Data Policy: Specific company names, subdomains, internal endpoints, and reproduction payloads are withheld from this public report in accordance with coordinated disclosure agreements and program terms of service. This document proves protocol usage, not target exposure.

2. Evidence Archive

2.1 Agent Outputs

All raw agent reasoning traces, GraphQL schema extractions, and endpoint mappings are preserved in the Origin Node’s private workspace under session lock. They are not reproduced here to prevent target identification.

2.2 Structural Invariants Evaluated

ID	Invariant	Status
$\Phi_{extauth}$	Authentication gates must precede all data access decisions	Preserved (validated across both targets)
$\Phi_{extsegregation}$	Public data nodes and private data nodes must remain type-incompatible	Preserved (verified via schema analysis)

Table 2 – continued

ID	Invariant	Status
$\Phi_{extpayment}$	Financial transaction states must never remain intermediate without rollback	Not testable (blocked by legitimate KYC/card requirements)
$\Phi_{extscope}$	Internal administrative services must not be reachable from public DNS	Rupture detected (service exposure identified, not exploited)

2.3 Ruptures and Potential Ruptures

Finding	Classification	Evidence Level	Action Taken
Publicly accessible API schema documentation	Information exposure / Attack surface	Confirmed (HTTP 200, public response)	Documented, not exploited
Internal identity-management bridge exposed to public DNS	Service exposure	Confirmed (HTTP 200 on public subdomain)	Documented, not exploited
Potential IDOR in seller-facing order operations	Potential invariant rupture	Blocked (requires seller API token unavailable to tester)	Classified as hypothesis; no exploitation attempted
Potential payment-amount manipulation in checkout flow	Potential invariant rupture	Blocked (requires KYC + real payment instrument)	Classified as hypothesis; no exploitation attempted
Public product taxonomy endpoint	Information exposure	Confirmed	Documented

2.4 Origin Node Confirmations

Every finding above was reviewed by the Origin Node before classification:

- **Confirmed findings** required reproducible HTTP responses.
- **Potential findings** were classified as hypotheses when exploitation was blocked by legitimate authentication or scope ambiguity.
- **No finding** was reported as a vulnerability without evidence.
- **No brute force, automated scanning, or data access** was performed against production systems.

2.5 Cryptographic Evidence

Session Export SHA-256: [PRESERVED IN PRIVATE ARCHIVE]
OpenTimestamps Attestation: [PRESERVED IN PRIVATE ARCHIVE]

The exact hashes of the confidential session exports are retained by the Origin Node. This public report itself is attested below.

3. Outcome Documentation

3.1 Did the protocol detect something a scanner missed?

Yes. Automated vulnerability scanners (SAST/DAST) typically flag implementation-level issues: SQLi, XSS, outdated libraries. SAP identified **structural attack surface** that scanners do not evaluate:

- Complete GraphQL schema exposure enabling systematic IDOR enumeration (if auth bypassed).
- Internal service bridge discoverable via public DNS (not a vulnerability per se, but a structural boundary violation).
- Type-level segregation between public and private data nodes (confirmed as correctly implemented, which is itself a valid audit result).

3.2 Did it propose structural remediation?

Yes. For each confirmed or potential rupture, the agent proposed architectural controls rather than local patches:

- **Schema exposure:** Recommendation to enforce authentication at the documentation gateway, not merely at the API resolver level.
- **Service exposure:** Recommendation to move internal bridges to private network segments with VPN/zero-trust access.
- **Potential IDOR:** Recommendation to implement resource-ownership validation as an invariant at the GraphQL middleware layer, not per-resolver.

3.3 Did it prevent a real failure?

Yes, operationally. By classifying high-value vectors as *potential* rather than *confirmed* when blocked by legitimate auth requirements, the protocol prevented:

- False-positive reports that would waste program triage time.
- Unauthorized access attempts that would violate program rules.
- Public disclosure of unverified hypotheses.

The protocol's **uncertainty management** functioned as designed: inconclusive findings were labeled hypotheses, not vulnerabilities.

3.4 Time Investment

Phase	Approximate Duration
Phase 0 —Conceptual Framework	2 hours
Phase 1 —Structural Reconnaissance	6 hours
Phase 2 —Invariant Analysis	4 hours
Phase 3 —System Analysis	8 hours
Phase 4 —Experimental Confirmation	4 hours
Phase 5 —Structural Solution Design	2 hours
Phase 6 —Strategic Report / Documentation	4 hours
Total	~30 hours over 5 days

4. Public Addendum

Use Case

Structural security auditing of public bug bounty programs using a symbiotic human-AI protocol.

Model Utilized

DeepSeek V4 Flash (via API interface).

Methodology

Symbiotic Architecture Protocol (SAP), six-phase invariant-based audit.

Findings Summary

- **2** confirmed information-exposure findings (attack surface, not exploitable vulnerabilities).
- **2** potential invariant ruptures classified as hypotheses (blocked by legitimate auth/KYC).
- **1** internal service exposure documented.
- **Multiple** invariants confirmed as preserved (authentication boundary, data segregation).

Limitations

- No critical exploitable vulnerability was identified in this session.
- High-value vectors (order manipulation, payment flow tampering) were blocked by legitimate access controls (API token requirements, KYC, real payment instruments).
- This is the **expected outcome** of a rigorous structural audit: not every session yields a CVE, but every session yields documented architectural intelligence.

Integrity Attestation

```
Document: docs/field_report_openrouter_v1.md
SHA-256: [TO BE COMPUTED UPON PUBLICATION]
OpenTimestamps: [TO BE SUBMITTED UPON PUBLICATION]
```

Compute the SHA-256 of this file after final edits, then submit to OpenTimestamps for immutable attestation. Link the .ots proof in the repository.

SAP — Symbiotic Architecture Protocol

Field Evidence of Operational Use

Invariant • Auditable • Traceable • Responsible